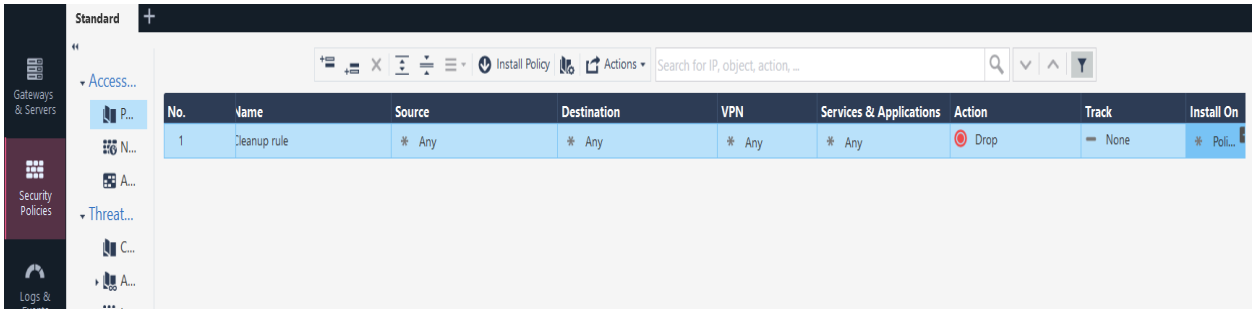
**Lab: Managing Security Policies**
**Course: CCSA104 Security Policy Management**
**Name: Ganiyu Ridwan Olayiwola**
**Reg No: C11/26/CCSA/17092**
**Date: 06/11/2026**

**Part A: Practical Tasks**
**Task 1: Exploring the default policy**

– The name of the security policy in use when the smart console was opened is the access policy, where the default policy which is clean up rule can be well seen.

–

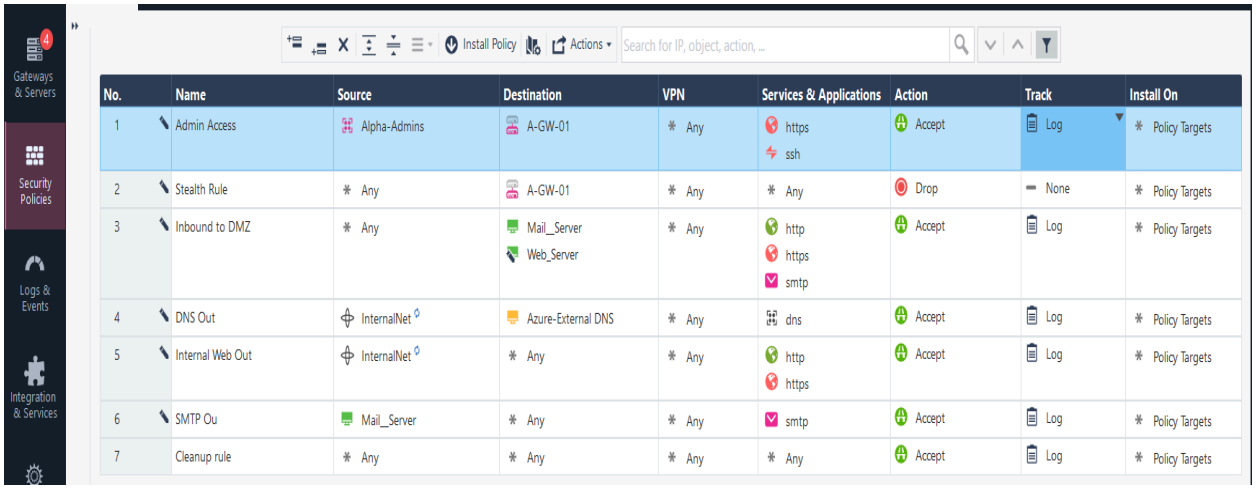



As seen in the image above, The clean up rule is the rule in display, the source is set to ANY, destination is set to ANY, vpn, which can only be modified by the main administrator is set to ANY, service & application is set to ANY, action is set to DROP, track is set to NONE, while the rule is set to be installed on POLICY TARGETS. All of these can be seen in the image attached above

– These are three of the settings that are available under Global properties. They are;
Fire wall
Remote access
Log and alert

While under manage policies and layers, it has;
Policies
Layers; which under the layers, there are access prevention, threat control and HTTPS inspection

## Task 2: Build the Access Control rulebase




| No. | Name | Source | Destination | VPN | Services & Applications | Action | Track | Install On |
|---|---|---|---|---|---|---|---|---|
| 1 | Admin Access | Alpha-Admins | A-GW-01 | Any | https<br>ssh | Accept | Log | Policy Targets |
| 2 | Stealth Rule | Any | A-GW-01 | Any | Any | Drop | None | Policy Targets |
| 3 | Inbound to DMZ | Any | Mail_Server<br>Web_Server | Any | http<br>https<br>smtp | Accept | Log | Policy Targets |
| 4 | DNS Out | InternalNet | Azure-External DNS | Any | dns | Accept | Log | Policy Targets |
| 5 | Internal Web Out | InternalNet | Any | Any | http<br>https | Accept | Log | Policy Targets |
| 6 | SMTP Ou | Mail_Server | Any | Any | smtp | Accept | Log | Policy Targets |
| 7 | Cleanup rule | Any | Any | Any | Any | Accept | Log | Policy Targets |

## Task 4: Organising the rulebase with sections

The image below shows the organisation of the rules base under different sections, this shows the expanded version

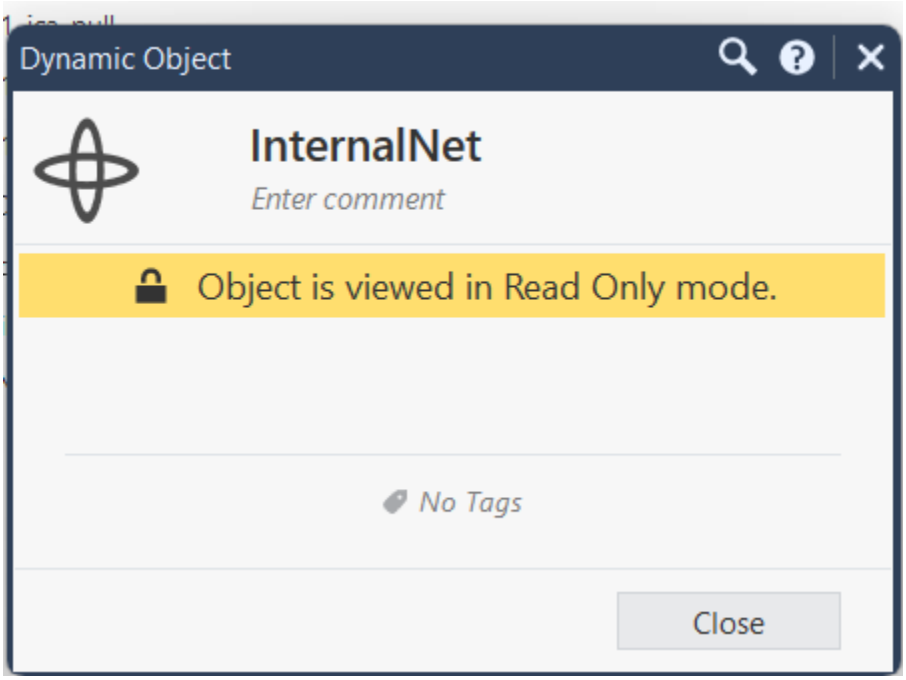
| No. | Name | Source | Destination | VPN | Services & Applications | Action | Track |
|---|---|---|---|---|---|---|---|
| Management and Protection (1-2) | | | | | | | |
| 1 | Admin Access | Alpha-Admins | A-GW-01 | Any | https<br>ssh | Accept | Log |
| 2 | Stealth Rule | Any | A-GW-01 | Any | Any | Drop | Log |
| DMZ Services (3-4) | | | | | | | |
| 3 | Inbound to DMZ | Any | Mail_Server<br>Web_Server | Any | http<br>https<br>smtp | Accept | Log |
| 4 | Internal to DMZ | Any | Any | Any | Any | Drop | Log |
| Outbound Access (5-7) | | | | | | | |
| 5 | DNS Out | InternalNet | Azure-External DNS | Any | dns | Accept | Log |
| 6 | Internal Web Out | InternalNet | Any | Any | http<br>https | Accept | Log |
| 7 | SMTP Out | Mail_Server | Any | Any | smtp | Accept | Log |
| Cleanup Rule (8) | | | | | | | |
| 8 | Cleanup rule | Any | Any | Any | Any | Accept | Log |

While the image below shows the collapse of the management and protection section while the other sections are expanded

| No. | Name | Source | Destination | VPN | Services & Applications | Action | Track |
|---|---|---|---|---|---|---|---|
| Management and Protection (1-2) | | | | | | | |
| DMZ Services (3-4) | | | | | | | |
| 3 | Inbound to DMZ | Any | Mail_Server<br>Web_Server | Any | http<br>https<br>smtp | Accept | Log |
| 4 | Internal to DMZ | Any | Any | Any | Any | Drop | Log |
| Outbound Access (5-7) | | | | | | | |
| 5 | DNS Out | InternalNet | Azure-External DNS | Any | dns | Accept | Log |
| 6 | Internal Web Out | InternalNet | Any | Any | http<br>https | Accept | Log |
| 7 | SMTP Out | Mail_Server | Any | Any | smtp | Accept | Log |
| Cleanup Rule (8) | | | | | | | |
| 8 | Cleanup rule | Any | Any | Any | Any | Accept | Log |

**Task 6: Configure Hide NAT**

The internalNet object is configured for read only mode and can only be modified by the super-admin as seen in the image




**Explanation**

**Why is this an automatic NAT rule rather than a manual one?**

When the "Add Automatic Address Translation Rules"is ticked inside the object itself, Check Point generates the NAT rule directly from the object's own properties. You did not go to the NAT rulebase and build a row yourself, the system read the configuration set on InternalNet or internal_LAN and created the rule on your behalf when you published. That is what makes it automatic. A manual NAT rule is one you create yourself in the NAT rulebase, filling in every column (original source, original destination, original service, translated source, translated destination, translated service) by hand. Manual rules give you more precise control but require you to manage every detail.

**What does many-to-one translation mean?**

Hide NAT is many-to-one translation. Many internal hosts, i.e every IP address in the InternalNet range, all share a single outward-facing IP address, which is the gateway's external interface address. From the internet's perspective, all traffic coming from your internal network appears to originate from that one IP. The inside has many addresses; the outside sees only one. This is in contrast to Static NAT, which is one-to-one, one internal IP maps to one dedicated external IP permanently, used when an internal server must be reachable from outside on a fixed address.

**What does the gateway do with the source port?**

Since many internal hosts are sharing a single external IP, the gateway cannot use IP addresses alone to tell return traffic apart. When an internal host opens a connection and its source IP is translated to the gateway's external address, the gateway also replaces the source

port with a unique port number it has selected from a tracking table. The gateway maintains a connection state table that records the original internal IP, the original source port, and the new translated port it assigned. When a reply packet comes back from the internet addressed to the gateway's external IP on that specific port, the gateway looks it up in the table, reverses the translation, and forwards the packet to the correct internal host on the correct original port. This mechanism is called Port Address Translation (PAT) or NAT overload, it is what allows thousands of internal hosts to share a single external IP simultaneously without their sessions colliding.

**5. Part B: Theory Questions**
**Section B1: Multiple choice**
**Answers**
Q1– B. Created in SmartConsole, stored on the Security Management Server, enforced by Security Gateways.
Q2– A. Positive Control Model (whitelist).
Q3 – C. As early as possible, typically immediately after the Management rules.
Q4– D. Sections are visual divisions only and do not affect enforcement order.
Q5– B. Many-to-one.

**Section B2: Short answers**
**Q6.** Distinguish between Explicit rules and Implied rules. State where Implied rules are configured and where they can be placed. What is the Implicit Cleanup Action?

Answer– Explicit rules are the rules an administrator creates manually in the rulebase inside SmartConsole. They are fully visible, editable and can be reordered at will. While Implied rules are generated automatically by Check Point based on settings in Global Properties. They handle traffic that Check Point's own components require to function, such as the SmartConsole management connection, logging traffic between the gateway and the log server. They do not appear in the standard rulebase view by default.

Implied rules are configured in Global Properties, found under the SmartConsole main menu. Each implied rule can be positioned in one of three places: First (processed before all explicit rules), Before Last (processed after all explicit rules but before the implicit cleanup), or Last (processed after the implicit cleanup, rarely used).

The Implicit Cleanup Action is the built-in final disposition for any traffic that has not matched any explicit or implied rule. By default it is Drop without logging. It is distinct from the administrator-created Cleanup rule, which is a visible explicit rule that explicitly drops and logs unmatched traffic so there is a record of what was silently discarded.

**Q7. Explain why rule order matters in a rulebase. Give one example from your own rulebase.**

Answer- Rule order matters in rule base because the firewall reads rules strictly from top to bottom and applies the action of the first rule that matches a packet. Once a match is found, processing stops and no later rules are considered. This means a broad permissive rule placed high in the rulebase can shadow more specific restrictive rules below it, rendering them unreachable.
A concrete example from the lab rulebase: the Cleanup rule sits at the very bottom with Action Drop covering Any source, Any destination and Any service. If that rule were accidentally moved to the top, it would match every single packet before any permit rule was evaluated, and all traffic through the gateway would be dropped. Rule order directly determines what traffic is permitted or denied.

**Q8. Explain the difference between saving and publishing changes in SmartConsole. What happens to unpublished changes when you install a policy, and why do many organisations publish only during a change window?**

Answer– Saving keeps changes within the administrator's own private session on the SMS. The changes are not visible to other administrators and are not eligible to be installed on a gateway. It is a local checkpoint only.

Publishing commits the session to the shared SMS database. The changes become visible to all administrators, a new database revision is created that can be rolled back to, and the changes are now eligible to be compiled and pushed to gateways via Install Policy.

Unpublished changes are never included in a policy installation. If an administrator runs Install Policy while another administrator has unpublished edits, those edits are simply ignored,  only the last published version is compiled and pushed.
Many organisations restrict publishing to defined change windows, typically scheduled maintenance periods outside business hours  because publishing makes changes immediately installable by any authorised administrator. In a production environment, an unreviewed or untested change that reaches a live gateway could drop legitimate traffic or open an unintended hole. The change window enforces a review and approval gate between editing and enforcement.

**Q9. Compare Global Properties with Policy Packages. Give one example of what each controls and say how you open each in SmartConsole.**

Answer – Global Properties are system-wide settings that apply across all policies and all gateways in the management domain. They are not part of any one policy package. An example of what Global Properties controls: whether implied rules for SmartConsole management connections are enabled and whether they are placed first or before last.

While Policy Package is a named collection of policy layers, which is typically an Access Control layer and a NAT layer, optionally with Threat Prevention and HTTPS Inspection, that is installed as a unit on one or more specific gateways. Different gateways can have different packages. An example of what a Policy Package controls: the specific Access Control rules that determine which traffic is permitted between InternalNet and the internet for the gateways it is installed on.

**Q10. Name the four predefined Security Zones. State two rules about assigning gateway interfaces to zones, and one benefit of using zone-based rules.**

Answer – The four predefined zones are **InternalZone, ExternalZone, DMZZone and WirelessZone**, which are all visible in the Objects panel

The two rules about assigning interfaces to zones are;

1. Each gateway interface can be assigned to only one zone, that is, an interface cannot belong to two zones simultaneously.
2. Second, the interface's zone assignment must reflect its actual network role, so the interface connecting to the internet must be assigned to ExternalZone and internal-facing interfaces assigned to InternalZone or DMZZone accordingly.

One benefit of zone-based rules is that they decouple the policy from specific IP addresses. If a new internal subnet is added to the network and its interface is assigned to InternalZone, every existing zone-based rule that references InternalZone automatically applies to it. No rulebase edits are required, reducing administrative overhead and the risk of forgetting to update individual network-object-based rules.

**Section B3: Scenario questions**

**Q11. A new administrator inserts a rule with Source Any, Destination Any, Services Any and Action Accept above the Stealth rule. Describe two security problems this causes, explain how to correct it, and name the type of rule that is allowed to sit above the Stealth rule and why.**

Answer –

First security problem: The Stealth rule is completely bypassed. The Any/Any/Accept rule matches all traffic before the Stealth rule is ever reached, meaning the gateway itself is now reachable from any source on any service. An attacker can attempt to SSH, HTTPS or telnet directly to the firewall's IP address, which is something the Stealth rule exists specifically to prevent. Direct access to the gateway is one of the most dangerous exposures in a firewall policy.

Second security problem: Every rule below the new Any/Any/Accept rule becomes dead code. Because the first matching rule wins and Any/Any/Any matches everything, no packet will ever reach the specific permit rules, the zone-based restrictions, the Stealth rule, or the Cleanup rule below it. The entire intended policy is bypassed. All traffic from anywhere to anywhere is permitted regardless of what every other rule says.

How to correct it: Delete the Any/Any/Any/Accept rule immediately. Confirm the Stealth rule is correctly positioned after the Management rules. Run Install Policy to push the corrected

rulebase to the gateway. Review the logs for the period the misconfiguration was active to identify any unauthorised access attempts.

The type of rule that is legitimately allowed above the Stealth rule is the Management rules, also called Administrative Access rules. These permit specific Check Point management traffic, such as the SmartConsole connection on port CPMI, from explicitly named, trusted administrator source IP addresses to the gateway. They must sit above the Stealth rule because the Stealth rule blocks all direct access to the gateway, and without an exception above it, administrators would lock themselves out of management. The critical difference from the malicious rule is specificity: management rules define exact sources, exact services and exact destinations, never Any.

**Q12. After Hide NAT is configured for Internal_LAN, staff report they cannot reach the Internet.**

**(a) State two benefits of NAT. (2 marks)**

**(b) Describe three checks you would make to find the fault, and explain why each one matters. (3 marks)**

Answer

A. Two benefits of NAT:

1. The conservation of public IPv4 address space. Many internal hosts share a single external IP address, so an organisation needs only one routable public IP for all outbound internet traffic rather than one per internal host.
2. internal network concealed with NAT. External systems see only the gateway's public IP as the source of all outbound traffic. The internal addressing scheme involves how many hosts exist, their IP ranges, the network layout which is never exposed to the internet, making reconnaissance harder for attackers.

B. Three checks and why each matters:
Check one – Confirm Install Policy was run after publishing. Publishing writes the NAT rule to the SMS database but does not push it to the gateway. The gateway enforces only the last installed policy version. If Install Policy was not run, the gateway is still using the old policy with no NAT rule. Outbound packets from internal hosts leave with their private source addresses intact, and internet routers discard them because private addresses are not publicly routable. Verify by right-clicking the gateway in Gateways & Servers and checking which policy version is currently installed.

Check two – Confirm an outbound Access Control rule exists for InternalNet. NAT is processed after the Access Control policy makes its permit or deny decision. If there is no rule in the Access Control layer that explicitly allows traffic from InternalNet to the internet (ExternalZone or Any), the firewall drops the packet before NAT ever runs. The staff would see a connection

failure that looks identical to a NAT failure. Check the Access Control rulebase for a rule with Source InternalNet, Destination Any or ExternalZone, and Action Accept.

Check three – Verify the Hide Behind setting targets the correct address. Open the InternalNet object, go to its NAT tab, and confirm that Hide Behind is set to Gateway rather than a specific IP address. If a specific IP was entered and that IP does not belong to the gateway's external interface, the gateway translates the source to an address it does not own. Return packets from the internet are addressed to that non-existent IP and never arrive back at the gateway, so sessions silently fail. Also check the NAT rulebase to confirm the auto-generated rule shows InternalNet in the Original Source column and the gateway object in the Translated Source column.